	RV College of Engineering® **Department of Computer Science and Engineering** **CIE - I**		
Course & Code	**Vulnerability Assessment & Penetration Testing (CY255TBD)** **Professional Core Course Elective-I**		**Semester: V**
Date: 27/11/2024	**Duration:**120 minutes	**Max.Marks** : 10 Marks (Quiz) + 50 Marks (Test)	
Scheme and Solution			

Sl.no.	Part A Quiz	Marks
1	CVSS - common vulnerability scoring system	01
2	Human Emotion	01
3	Meet-in-the-Middle Attack or The Meeting attack	01
4	Detection: Actively monitoring for signs of exploitation and staying informed through threat intelligence feeds. Mitigation: Implementing temporary controls, such as access restrictions, disabling vulnerable features, or using web application firewalls, until a permanent fix is available. Patch Management: Applying patches or updates as soon as they are released by the vendor. Incident Response: Having an incident response plan in place to quickly address any exploitation attempts. Communication: Informing stakeholders about the vulnerability and the steps being taken to mitigate the risk.	02
5	FTP (port 20, 21) SSH (port 22) Telnet (port 23) SMTP (port 25) HTTP (port 80) NTP (port 123) HTTPS (port 443	02
6	John the Ripper is a computer security tool (password cracking) used by penetration testers to test the security of a computer system. It is a command-line tool that can be used to test the security of various file formats. It can also be used to extract data from a target computer.	01
7	A black box test is a simulation of an attack from an external attacker, a white box test is a comprehensive review of an application's source code, and a grey box test is a combination of black box and white box testing.	02

<table>
<tr><th>Sl.no.</th><th>Part B Test</th><th>Marks</th></tr>
<tr><td>1.a</td><td>
<table>
<tr><th>S.No.</th><th>Penetration Testing</th><th>Vulnerability Assessments</th></tr>
<tr><td>1.</td><td>This is meant for critical real-time systems.</td><td>This is meant for non-critical systems.</td></tr>
<tr><td>2.</td><td>This is ideal for physical environments and network architecture.</td><td>This is ideal for lab environments.</td></tr>
<tr><td>3.</td><td>It is non-intrusive, documentation and environmental review and analysis.</td><td>Comprehensive analysis and through review of the target system and its environment.</td></tr>
<tr><td>4.</td><td>It cleans up the system and gives final report.</td><td>It attempt to mitigate or eliminate the potential vulnerabilities of valuable resources.</td></tr>
<tr><td>5.</td><td>It gathers targeted information and/or inspect the system.</td><td>It allocates quantifiable value and significance to the available resources.</td></tr>
<tr><td>6.</td><td>It tests sensitive data collection.</td><td>It discovers the potential threats to each resource.</td></tr>
<tr><td>7.</td><td>It determines the scope of an attack.</td><td>It makes a directory of assets and resources in a given system.</td></tr>
<tr><td>8.</td><td>The main focus is to discovers unknown and exploitable weaknesses in normal business processes.</td><td>The main focus is to lists known software vulnerabilities that could be exploited.</td></tr>
<tr><td>9.</td><td>It is a simulated cyberattack carried out by experienced ethical hackers in a well-defined and controlled environment.</td><td>It is an automated assessment performed with the help of automated tools.</td></tr>
<tr><td>10.</td><td>This is a goal-oriented procedure that should be carried out in a controlled manner.</td><td>This cost-effective assessment method is often considered safe to perform.</td></tr>
<tr><td>11.</td><td>It only identifies the exploitable security vulnerabilities.</td><td>It identifies, categorizes, and quantifies security vulnerabilities.</td></tr>
</table>
</td><td>06</td></tr>
<tr><td>1.b</td><td>False Positives/Negatives: Scans can sometimes report incorrect vulnerabilities, requiring further validation.
Prioritization: With hundreds or thousands of vulnerabilities, deciding which to address first can be complex.
Continuous Updating: New vulnerabilities are discovered regularly, so assessments must be ongoing.
Any four challenges with brief explanation- 4marks</td><td>04</td></tr>
<tr><td>2.a</td><td>1. Injection Attacks
SQL Injection: Attackers insert malicious SQL code into a query to access or manipulate databases.
Command Injection: Executing arbitrary commands on a server, leading to unauthorized access or system control.
Cross-Site Scripting (XSS): Injecting malicious scripts into web pages viewed by other users, allowing attackers to impersonate users or steal information.
2. Broken Authentication and Session Management
Weak Passwords: Easily guessable passwords or poor password management practices.
Session Hijacking: Attacking active user sessions to gain unauthorized access.
Exposed Session IDs: Using exposed session tokens to impersonate users.
3. Sensitive Data Exposure
Unencrypted Data: Storing or transmitting data without encryption, allowing attackers to intercept sensitive information.</td><td>06</td></tr>
</table>

	Insufficient Encryption Standards: Using weak or outdated encryption algorithms that can be cracked 4.Security Misconfiguration Default Configurations: Using default settings or passwords, which attackers can exploit. Unpatched Software: Failing to apply updates or security patches, making systems vulnerable to known attacks. 5. Cross-Site Request Forgery (CSRF) CSRF Attacks: Trick users into performing unwanted actions on authenticated websites, like transferring funds or changing settings. 6. Broken Access Control Excessive Privileges: Users or applications have more permissions than necessary. Directory Traversal: Attackers access restricted files or directories by manipulating URL paths. 7. Insecure Deserialization Malicious Object Injection: Exploiting deserialization to insert malicious objects or commands that compromise applications. 8. Insufficient Logging and Monitoring No Auditing: Failure to log actions and monitor systems can delay detection of breaches. Inadequate Monitoring: Lack of alerts for suspicious activities can lead to prolonged data breaches. 9. Outdated Components Legacy Systems: Using outdated software or hardware with known vulnerabilities. Unsupported Software: No longer receiving security patches, which makes systems easy targets. 10. Insufficient Transport Layer Protection Unencrypted Connections: Using HTTP instead of HTTPS, which can expose data to interception. Weak TLS Configurations: Using older TLS/SSL protocols vulnerable to attacks like BEAST or POODLE.	
2.b	• Actually teach security professionals what the bad guys already know and are doing. • Why do militaries all over the world study their enemies' tactics, tools, strategies, technologies. • Most countries' militaries carry out various scenario-based fighting exercises. • Base is so dependent upon technology and Software-Communication channels • different type of "security police" is required to cover and monitor all of these entry points into and out of the base. • An interesting aspect of the hacker community is that it is changing. • Thrill of figuring out how to exploit vulnerabilities to figuring out how to make revenue from their actions and getting paid for their skills. • Gaining financial benefits from their activities. • joy riding to hacking as an occupation. Examples: • hack, pump, and dump scheme, Russian hacking group called the Russian Business Network (BSN) stole tens of millions of dollars from Citibank etc. • Criminals are also using online scams in a bid to steal donations • Malware is still one of the main culprits that costs companies the most amount of money. • The commands and logic within the malware are the same components that attackers used to have to carry out manually.	04

3	1. Form two or three teams:
	• Red team—The attack team
	• White team—Network administration, the victim
	• Blue team—Management coordinating and overseeing the test (optional)
	2. Establish the ground rules:
	• Testing objectives
	• What to attack, what is hands-off
	• Who knows what about the other team (Are both teams aware of the other? Is the testing single blind or double blind?)
	• Start and stop dates
	• Legal issues
	  • Just because a client asks for it, doesn't mean that it's legal.
	  • The ethical hacker must know the relevant local, state, and federal laws and how they pertain to testing procedures.
	• Confidentiality/Nondisclosure
	• Reporting requirements
	• Formalized approval and written agreement with signatures and contact information
	  • Keep this document handy during the testing. It may be needed as a "get out of jail free" card
		10

	3. Passive scanning: Gather as much information about the target as possible while maintaining zero contact between the penetration tester and the target. Passive scanning can include interrogating. The company's website and source code • Social networking sites • Whois database • Edgar database • Newsgroups • ARIN, RIPE, APNIC, LACNIC databases • Google, Monster.com, etc. • Dumpster diving **4. Active scanning** Probe the target's public exposure with scanning tools, which might include: Commercial scanning tools • Banner grabbing • Social engineering • War dialing • DNS zone transfers • Sniffing traffic • Wireless war driving **5. Attack surface enumeration** Probe the target network to identify, enumerate, and document each exposed device: • Network mapping • Router and switch locations • Perimeter firewalls • LAN, MAN, and WAN connections **6. Fingerprinting** Perform a thorough probe of the target systems to identify: • Operating system type and patch level • Applications and patch level • Open ports • Running services • User accounts **7. Target system selection** Identify the most useful target(s). **8. Exploiting the uncovered vulnerabilities** Execute the appropriate attack tools targeted at the suspected exposures. • Some may not work. • Some may kill services or even kill the server. • Some may be successful. **9. Escalation of privilege** Escalate the security context so the ethical hacker has more control. • Gaining root or administrative rights • Using cracked password for unauthorized access • Carrying out buffer overflow to gain local versus remote control **10. Documentation and reporting** Document everything found, how it was found, the tools that were used, vulnerabilities that were exploited, the timeline of activities, and successes, etc.	
4	• simulating cyberattacks to identify vulnerabilities in a system. • Larger penetration test, we'll only cover the social engineering portion of the attack. **Attacks:** • The Good Samaritan • The Meeting attack • Join the Company attack **1.The Good Samaritan:** • Attackers exploit human emotions and trust to bypass technical security measures. • Target's willingness to help others. • both digital and physical contexts to bypass security or extract sensitive information. Steps: 1. Creating a Scenario of Need 2. Exploiting the Victim's Trust 3. Executing the Exploit Examples of the Good Samaritan Attack • Malicious USB Drives	10

- Fake Customer in Retail
- Tech Support Ruse

Defending Against Good Samaritan Attacks

- Employee Awareness
- Technical Safeguards
- Clear Security Policies
- Encourage Reporting
- Organizations must balance technological defenses with comprehensive employee education to mitigate this and other social engineering threats

2. The Meeting attack

- ***Meet-in-the-Middle Attack.***
- *cryptographic attack primarily used against encryption algorithms (Ex.* ***block ciphers*** *and* ***hash functions****)*
- *It reduces the effort needed to break the encryption by exploiting trade-offs between* ***time*** *and* ***memory****.*

Working:

1.Target*: The attack is typically used against encryption schemes that employ multiple encryption layers, such as double encryption (e.g., Double DES).*

2. Approach*:*

The attacker tries to compute both the encryption and decryption of the message until a match is found, reducing the effective security of the system.

Double DES, which encrypts a plaintext twice using two keys (K1 and K2)

- *Compute all possible encryptions of the plaintext with K1 and store the results.*
- *Compute all possible decryptions of the ciphertext with K2.*
- *Compare these two sets to find a match, significantly reducing the number of brute force operations.*

2. Approach*:*

The attacker tries to compute both the encryption and decryption of the message until a match is found, reducing the effective security of the system.

Double DES, which encrypts a plaintext twice using two keys (K1 and K2)

- *Compute all possible encryptions of the plaintext with K1 and store the results.*
- *Compute all possible decryptions of the ciphertext with K2.*
- *Compare these two sets to find a match, significantly reducing the number of brute force operations.*

Applications of the Attack:

- ***Block Ciphers****: Common against ciphers that use multiple encryption layers, such as 2DES or 3DES.*
- ***Cryptographic Protocols****: To test weaknesses in multi-stage encryption systems.*
- ***Hash Functions****: To find collisions in hash algorithms using similar methods.*

Mitigation Techniques:

- ***Use Larger Keys****: Increase key sizes to make brute-force attacks infeasible.*
- ***Use More Complex Designs****: Adopt encryption systems like AES, which are resistant to Meet-in-the-Middle attacks due to single encryption stages with strong mixing.*
- ***Key Management****: Avoid using algorithms that are vulnerable to this attack.*

3.Join the Company attack

Insider threat.

Attacker infiltrates an organization by gaining employment or physical access to the company.

Once inside, they exploit their access privileges to steal sensitive data, disrupt operations, or compromise security systems.

Key Features of the Attack:

- ➢ Entry Point:

The attacker applies for a job within the organization and gets hired.

Alternatively, they gain access through contractors, interns, or temporary positions.

- ➢ Execution:

Once inside, the attacker exploits their legitimate access to gather sensitive information, plant malware, or create backdoors.

They may blend in with employees to avoid detection while exfiltrating data or sabotaging systems.

- ➢ Motivation:

	Stealing intellectual property. Gaining access to trade secrets. Sabotaging the organization for financial gain, personal vendetta, or competitive advantage. ***Example Scenarios:*** ➢ Corporate Espionage: An attacker joins a rival company to steal proprietary designs, product plans, or customer data. ➢ Data Breach: A malicious insider plants malware or copies sensitive databases for personal or financial gain. ➢ Nation-State Attacks: A state-sponsored actor joins a defense or technology firm to obtain classified information. ***Detection and Mitigation Strategies:*** ➢ Background Checks: Perform thorough checks on all employees and contractors before hiring. ➢ Access Control: Implement least privilege policies to restrict access to only what is necessary for each role. ➢ Activity Monitoring: Monitor employee activity, especially on critical systems, for unusual behavior. ➢ Data Encryption: Encrypt sensitive data to minimize the impact of potential breaches. ➢ Regular Audits: Conduct frequent audits of access logs, security policies, and employee roles. ➢ Awareness Training: Educate employees about insider threats and the importance of reporting suspicious behavior.	
5.a	Risk Analysis and Penetration Testing are both important aspects of information security, however, they have some key differences. Risk Analysis is the process of identifying, quantifying, and assessing the potential risks associated with a security vulnerability, system, or process. Penetration Testing is the process of testing a system's vulnerability to attack by trying to exploit discovered vulnerabilities. Penetration Testing can be used to find vulnerabilities that could be harmful if exploited. When it comes to security, many organizations have a tendency of neglecting the perimeter. While this is understandable in the vast majority of cases, due to breaches that often originate from outside sources such as phishing and malware attacks, failing to properly secure your internal network can be shut down. A third-party penetration testing firm can help alleviate some of these problems by providing reliable and accurate information about vulnerabilities present in your organization's systems or networks. Additionally, they can provide guidance on how best to address them – whether through vulnerability assessment or remediation.	05
5.b	To strengthen its defenses against potential threats, Visma adopted the Qualys Cloud Platform for in-depth security scans. Qualys Vulnerability Management allowed the firm to automatically scan its development infrastructures and place the scan results in the same backlog with vulnerability reports on the company's code. It also provided the firm with a 360-degree view of vulnerabilities on its network that trickled down to individual devices. "We now have a comprehensive map of all 4,000 servers and 6,000 clients across our global IT infrastructure and an accurate view of all the vulnerabilities and their severity," says Hans Petter Holen, CISO, Visma. "We can perform scans in the background, even when a device is offline, and deliver the results as soon as it is reconnected to the network. When we detect a vulnerability, we deliver the findings to whoever is responsible for the machine — either via email to the local IT department or via Jira to the developer who owns the device." **Industry:** IT services **Vulnerability scanning provider:** Qualys **Outcomes:** • Vulnerability detection across more than 10,000 connected devices • Functions on minimal external management • Quarterly patching cycles accelerated up to 80%	05

	RV College of Engineering® **Department of Computer Science and Engineering** **CIE - I**		
Course & Code	**Vulnerability Assessment & Penetration Testing (CY255TBD)** **Professional Core Course Elective-I**		**Semester: V**
Date: 27/11/2024	**Duration:**120 minutes	**Max.Marks** : 10 Marks (Quiz) + 50 Marks (Test)	
USN :	**Name :**		

NOTE: ***Answer all the questions***

Sl.no.	Part-A Quiz	Marks	BT	CO
1	_____ is an industry-standard that vendors used to determine the severity of a vulnerability.	1	L1	CO5
2	_____ is the heart of every social engineering attack without which the attacks will not work.	1	L1	CO1
3	_____Attack reduces the effort needed to break the encryption by exploiting trade-offs between time and memory.	1	L2	CO3
4	How do you handle zero-day vulnerabilities?	2	L2	CO1
5	List the commonly targeted ports during penetration testing. Give example.	2	L2	CO1
6	What is John the ripper tool and how penetration testers are using it?	1	L1	CO1
7	Differentiate between a black box, white box, and grey box penetration test.	2	L1	CO1
	Part-B Test			
1.a	Differentiate between Vulnerability Assessment and Penetration Testing.	06	L2	CO2
1.b	List and briefly explain the common challenges in vulnerability assessment.	04	L2	CO1
2.a	Describe the most common vulnerabilities affecting organizations today. Discuss their causes, potential impacts, and strategies to mitigate these vulnerabilities.	06	L3	CO3
2.b	Why is it important to understand an attacker's tactics and how can this knowledge help to strengthen their defenses against potential threats?	04	L2	CO4
3	Outline the 10 steps involved in the penetration testing process. Explain the significance of each step and how it contributes to identifying and mitigating security vulnerabilities.	10	L3	CO2
4	Discuss any two common types of attacks used in penetration testing. Explain the purpose of each attack and their role in identifying vulnerabilities in an organization's security posture.	10	L3	CO5

5.a	Explain how risk analysis and penetration testing are different from each other. Why should penetration testing be carried out by a third party?	05	L2	CO4
5.b	With over one million customers across Europe and Latin America, Visma is a leading provider of accounting, procurement, and payroll solutions. Visma employs over 5,500 professionals and includes 200 companies spanning over 20 countries across the world. As the firm transformed into a software-as-a-service (SaaS) provider, newer challenges related to security emerged. Visma not only needs to ensure the security of its own systems, but it has the responsibility of safeguarding customer data as well. With a larger attack surface, Visma wanted to gain increased protection against potential cyberattacks by effectively detecting and remediating vulnerabilities. To strengthen its defenses against potential threats, Visma adopted the Qualys Cloud Platform for in-depth security scans. **Analyze how Visma addressed the cybersecurity challenges arising from its transformation into a SaaS provider. Discuss the role of the Qualys Cloud Platform in enhancing Visma's security infrastructure, focusing on the benefits achieved through its implementation. Include specific examples from the case study to support your answer.**	05	L3	CO5

BTL,CO	**L1**	**L2**	**L3**	**L4**	**L5**	**L6**	**CO1**	**CO2**	**CO3**	**CO4**	**CO5**
Marks	05	24	31	***	***	***	12	16	07	09	16